ERHVERVSAKADEMI KØBENHAVN

Lecture III

Link Layer Security

ARP, DHCP, Intro to Ethernet Switching, and Switch Security

Network & Communications Security

F26 EK IT-Sikkerhed

Network Core | DFIR

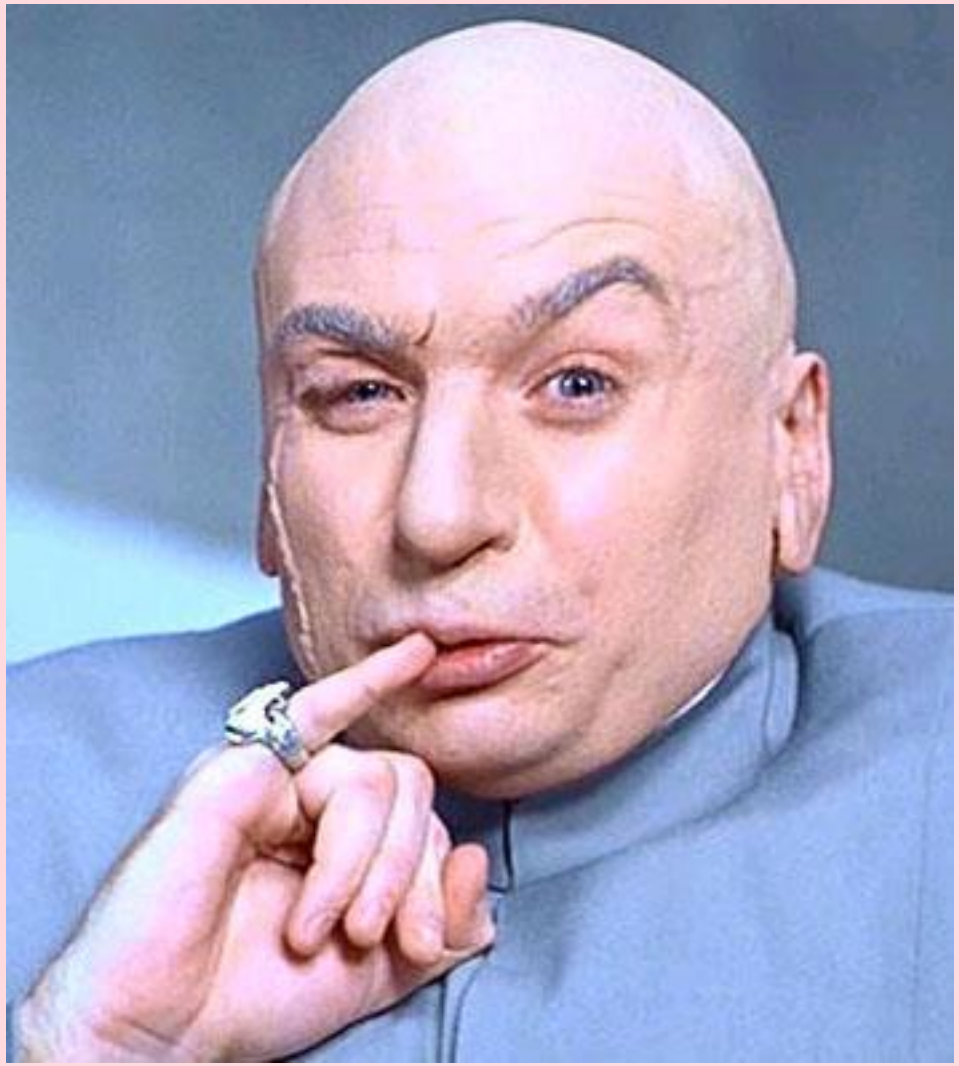
Attacks

- 5 min: Send your group members
- Link Layer usage
- Common protocols: STP, ARP…
- DHCP on Link layer
- Intro to Switch fundamentals + security
- Lab lesson



Let me test your Memory!

Kahoot!

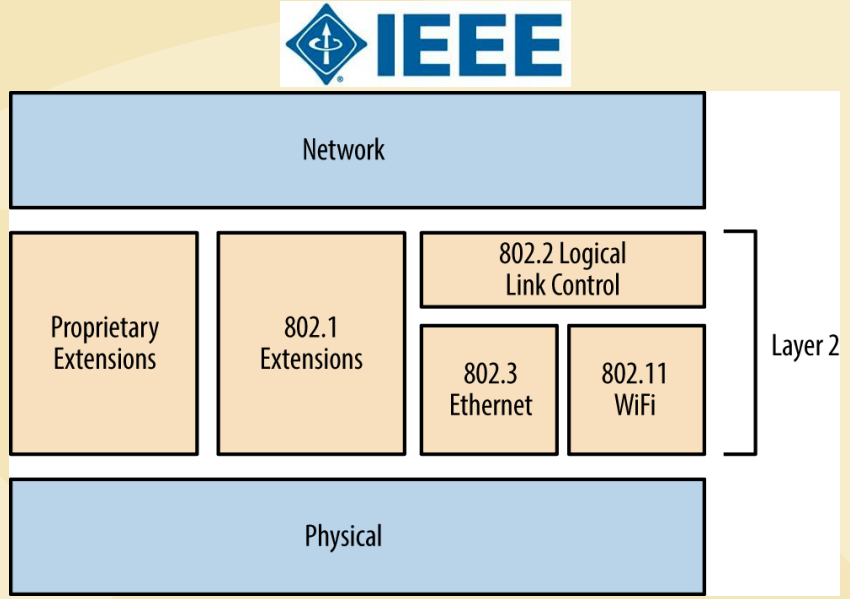


Link Layer

- Responsible for communication inside the local network (**LAN**).
- Protocol Data Unit: **Frame**
- Main identifiers (Addressing): **MAC addresses**

- Higher-layer traffic is encapsulated into Layer 2 frames for local delivery
- Devices often trust the local network by default
- Layer 2 protocols were designed for connectivity and simplicity
- Many Layer 2 protocols have little or no authentication
- A local attacker may discover, redirect, observe or disrupt traffic
- Layer 2 attacks can enable attacks against higher-layer protocols

Key idea: Being connected to the LAN creates (Offers) an attack surface.



IEEE = Institute of Electrical and Electronics Engineers. https://www.ieee.org/

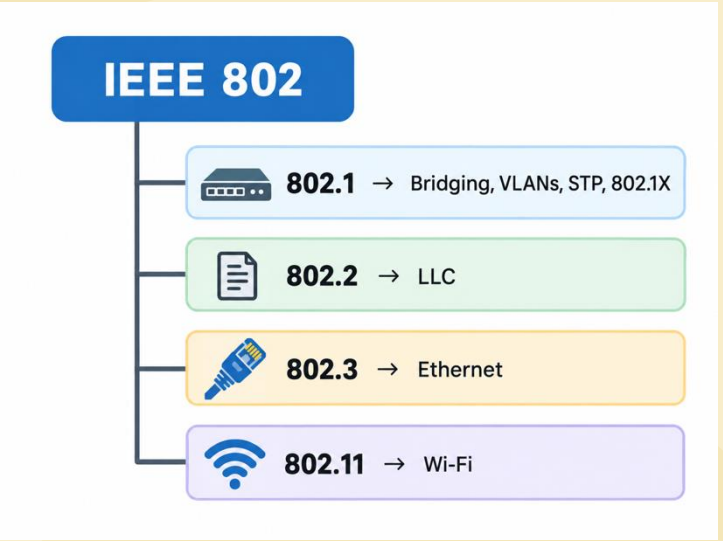
Link Layer: IEEE 802 families

IEEE 802.1 — Bridging & Network Management
- VLANs: **802.1Q**
- Spanning Tree Protocol (STP) : **802.1D**
- Port-based Network Access Control: **802.1X (RADIUS server)**
- Link Aggregation: originally **802.1AX**
- MACsec — **802.1AE**

IEEE 802.2 — Logical Link Control (LLC) LLC
- Provides the interface between Layer 2 MAC technologies and upper layers.

IEEE 802.3 — Ethernet:
- Includes many Ethernet standards such as **100BASE-TX, 1000BASE-T, 10GBASE-T**
- Ethernet MAC and physical specifications

IEEE 802.11 — Wireless LAN Wi-Fi:
- Examples: **802.11a/b/g/n/ac/ax/be**



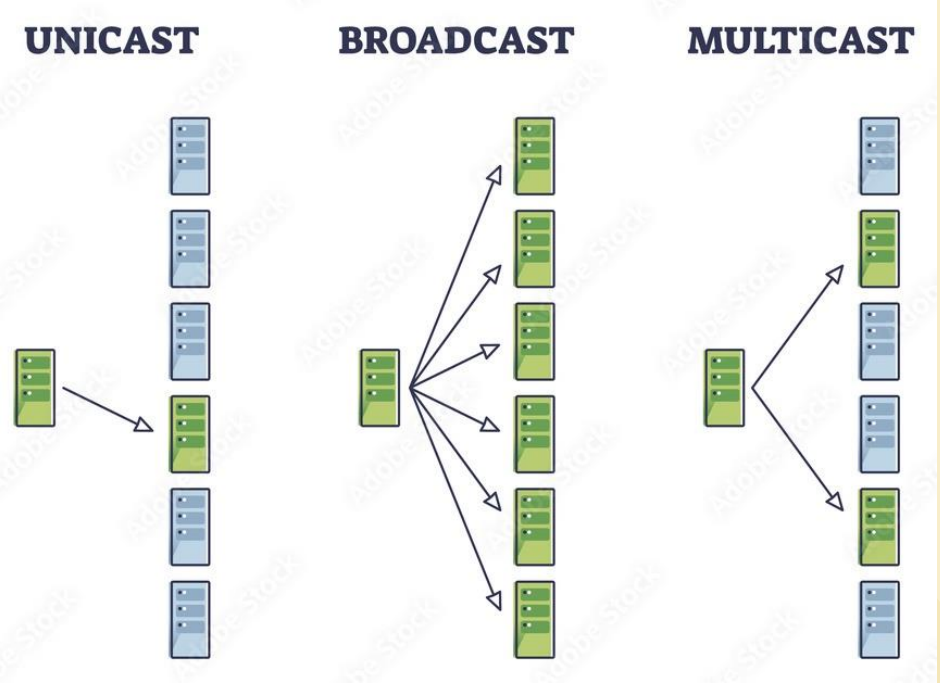
https://1.ieee802.org/

Quick Recap: Network fundamentals

Unicast: 1 to 1
- Host A → Host B
- 192.0.2.10 → 192.0.2.20
- Destination MAC: Host B MAC

Broadcast: 1 to all
- 192.0.2.10 → 192.0.2.255
- Destination MAC: FF:FF:FF:FF:FF:FF

Multicast:
- **1-to-many:** One sender sends to a selected group of receivers.
- **Many-to-many:** Multiple senders send to the same multicast group.
- **Many-to-1:** Multiple senders send to one receiver/group endpoint.



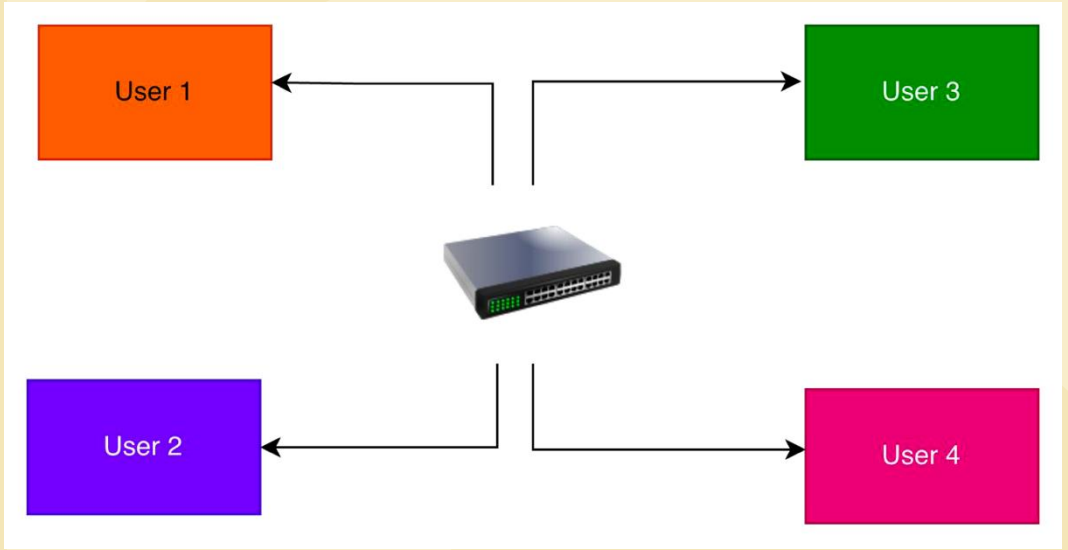
Link Layer

Scenario:

- All Users are on the same LAN. 192.168.1.0/24
- What is the difference about these 2 scenarios?



WiFi Access



Wired Access

Ethernet & MAC Addresses

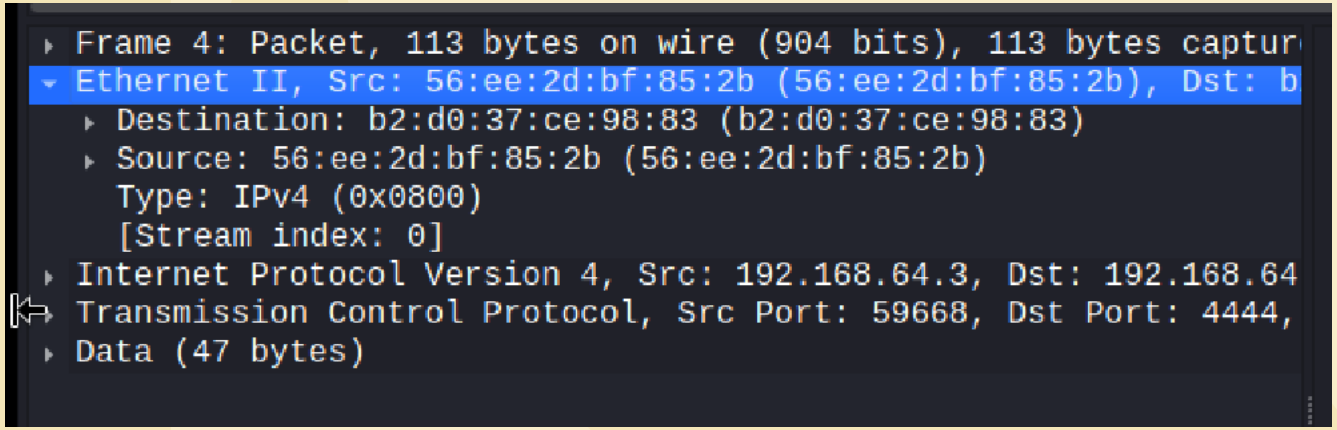
Ethernet provides local communication using MAC addresses.

A MAC address:

- Identifies a network interface on the local network
- Is normally 48 bits
- Is represented as six hexadecimal pairs
- **Example**: 08:00:27:A4:2B:19

Ethernet frames contain:

- Source MAC address
- Destination MAC address
- EtherType or length
- Payload (Data)
- Frame Check Sequence (FCS)



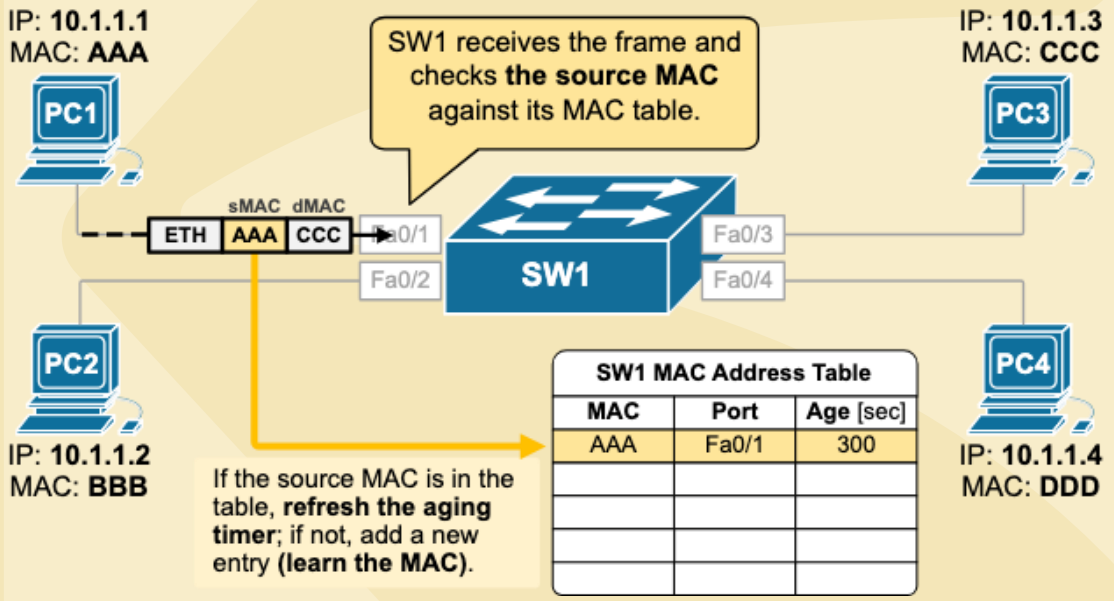
How a Switch Learns?

Receiving

A switch learns from the **source MAC address** of incoming frames.

This information is stored in the:

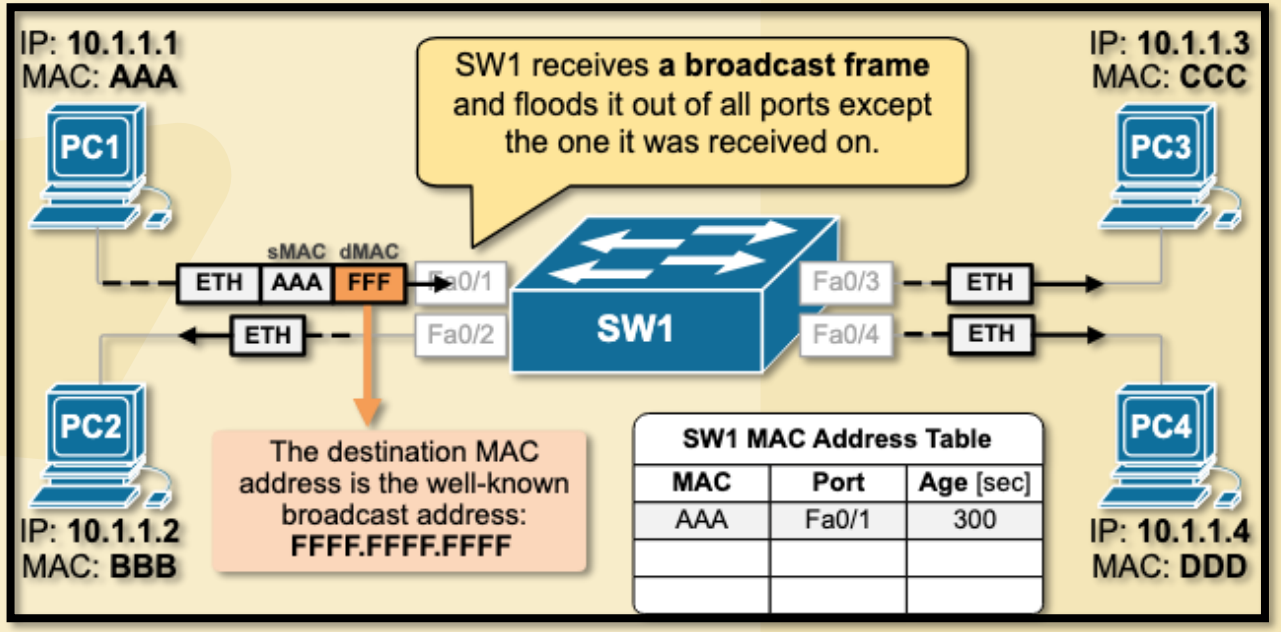
- **MAC Address Table / Forwarding Database (FDB)** Often implemented in hardware using **CAM (Content Addressable Memory).**
- Each learned entry associates a MAC address with a switch port:
- The entries are normally learned dynamically and expire after a period of inactivity. Cisco default is 300sec.



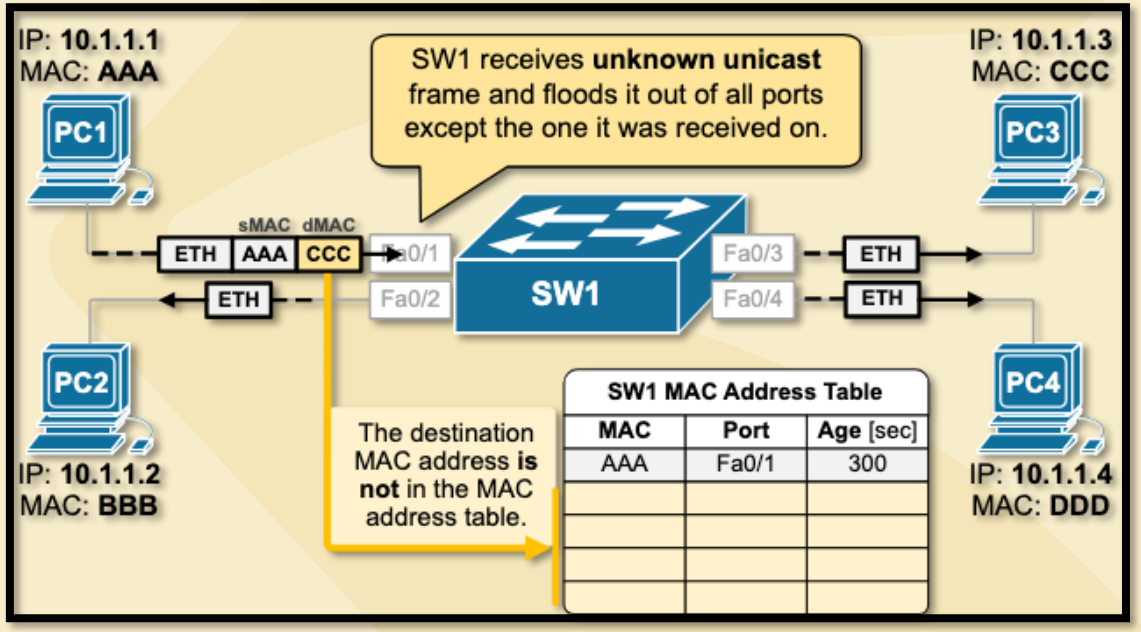
https://www.networkacademy.io/ccna/ethernet/switching-logic

How a Switch Learns?

Forwarding Decisions



Scenario 1: Broadcast frame



Scenario 2: Unicast frame

https://www.networkacademy.io/ccna/ethernet/switching-logic

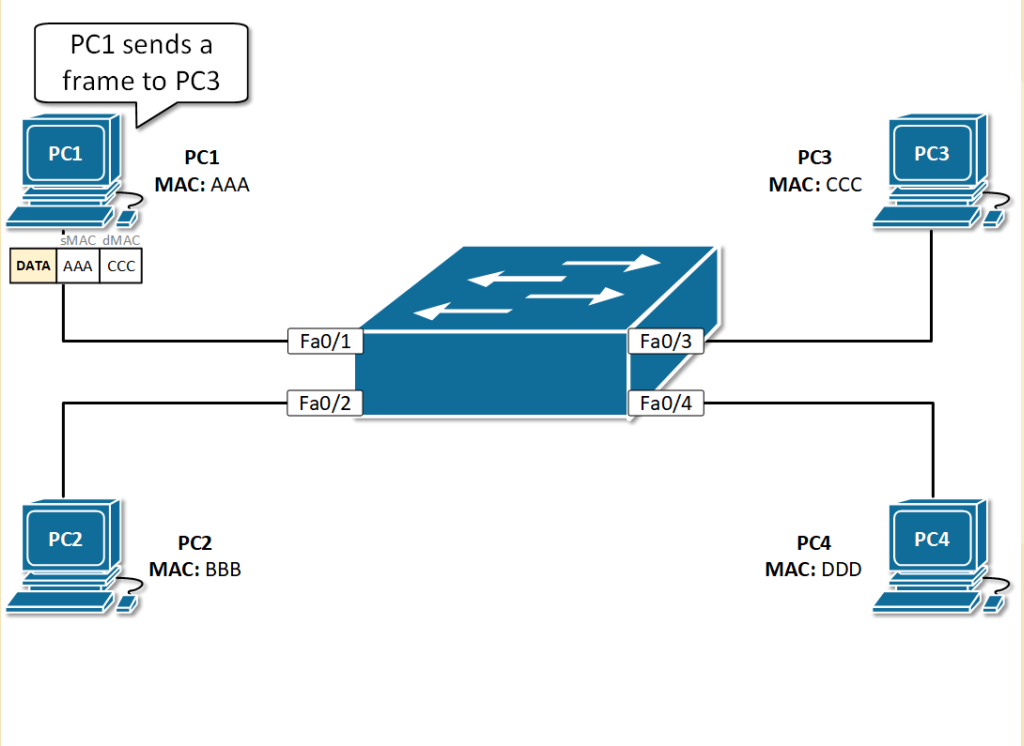
How a switch forwards Frames?

Known unicast
- The destination MAC exists in the MAC table.
- The frame is forwarded only through the associated port.

Broadcast
- The switch floods the frame to all ports in the same broadcast domain except the incoming port.

Unknown unicast
- The destination MAC is not yet known.
- Flood the frame to all relevant ports except the incoming port.

Do you see a problem here? Which scenario is concerning?

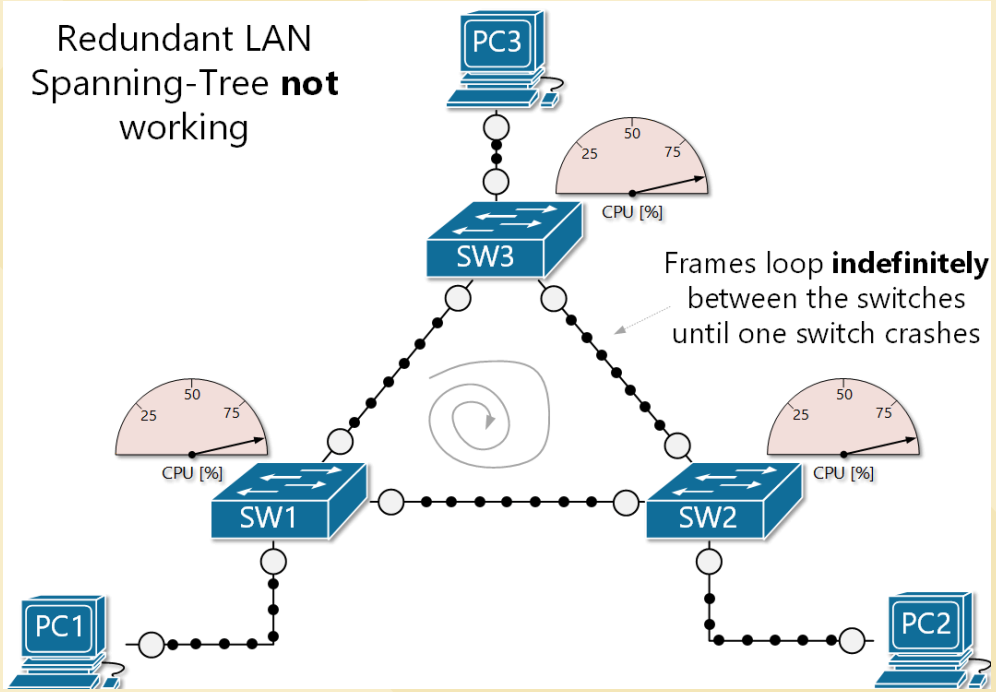


Network loops

A network loop happens when there are multiple Layer 2 paths between switches and Ethernet frames keep circulating endlessly in the network.

Ethernet frames do not have an IP-like TTL field, so Layer 2 loops can persist:

- Circulate forever
- Frames may be replicated repeatedly (Broadcast Storm)
- Consume all bandwidth
- Corrupt MAC address tables (MAC flapping)
- Bring the network down



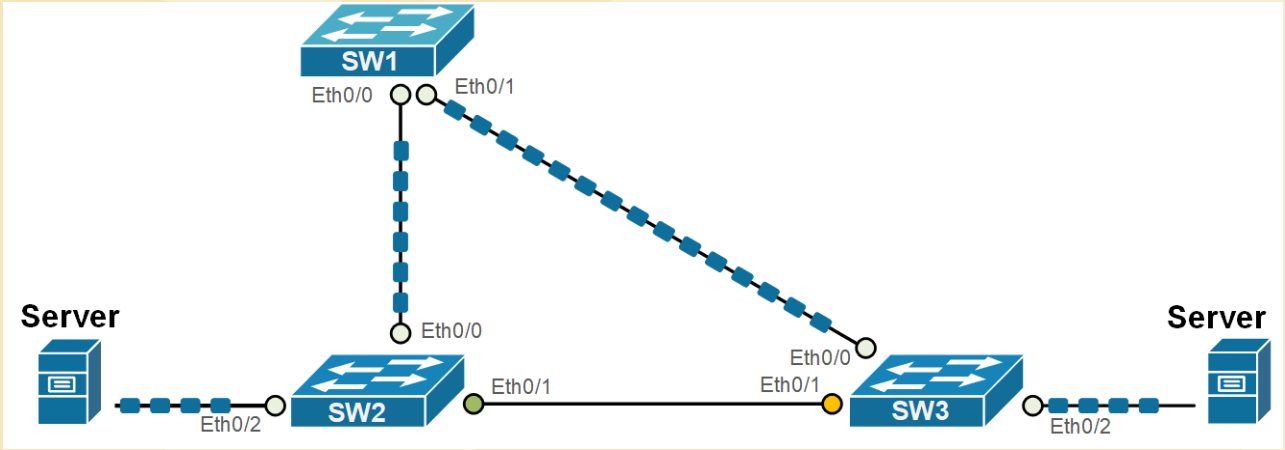
https://www.networkacademy.io/ccna/spanning-tree/spanning-tree-port-roles

STP 802.1D

Layer 2 protocol that prevents loops by logically blocking redundant paths while keeping them available as backups.

STP process

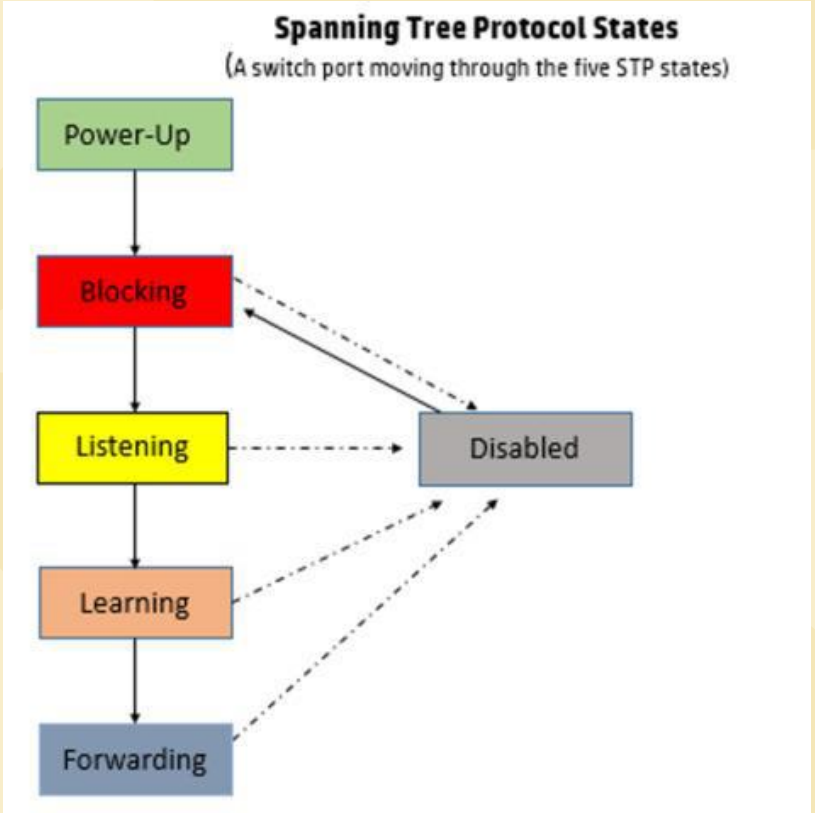
1. Elect the Root Bridge.
2. Select Root Ports (RPs).
3. Select Designated Ports (DPs).
4. Block Non-Designated Ports.
5. Monitor for failures.



https://www.networkacademy.io/ccna/spanning-tree/spanning-tree-port-roles

STP Port states

- **Disabled**: port is electrically inactive
- **Blocking**: discards data, only listen for **BPDUs**
- **Listening**: listens to BPDUs to build a loop-free tree
- **Learning**: builds forwarding table from source MAC addresses
- **Forwarding**: fully operational; forwards traffic



BPDU = Bridge Protocol Data Unit

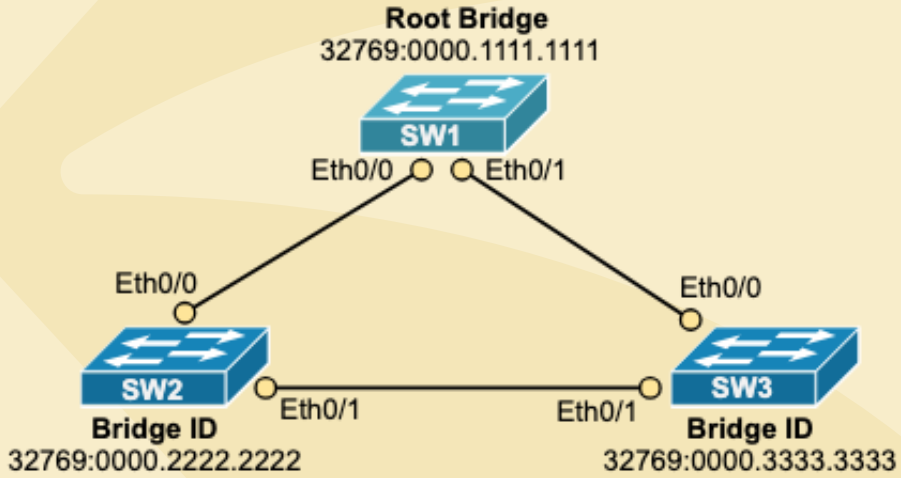
STP 802.1D

Step 1: Elect a Root Bridge

All switches exchange special frames called **BPDUs.**
The switch with the **lowest Bridge ID** becomes the **Root Bridge**.

Bridge ID = Priority + MAC Address

- Lower value wins
- Comparison starts from left (Priority first): Priority value
- MAC only matters if priorities are equal
- MAC addresses are compared based on binary/ hex values.
  - Ex: 0x001A2B3C4D5E < 0x00FF2B3C4D5E



Hexadecimal	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F
Decimal	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15

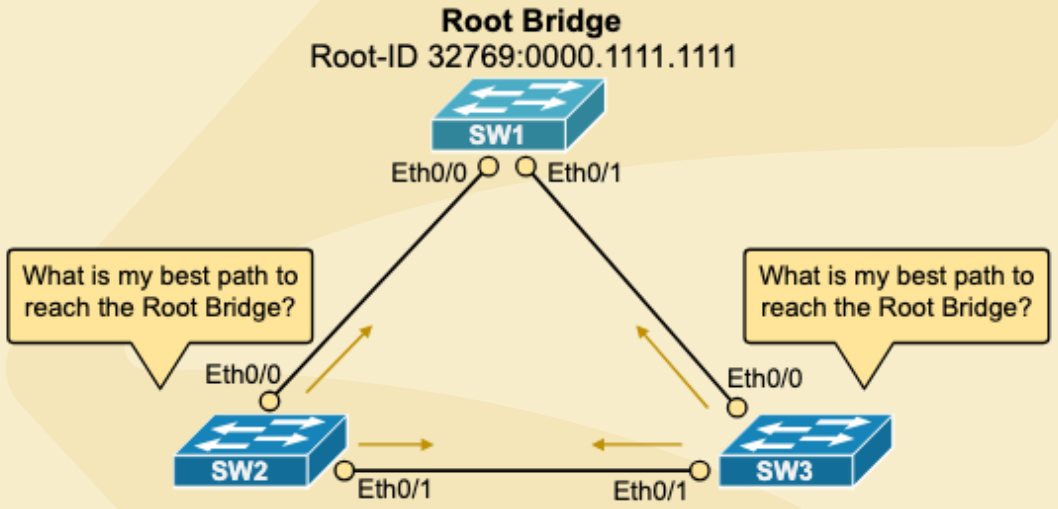
BPDU = Bridge Protocol Data Unit

STP 802.1D

Step 2: Select a Root Port (RP)

How STP Selects the Root Port (RP)

- Each non-root switch selects **one Root Port**.
- The RP is the port with the **lowest total cost** to the Root Bridge.
- The Root Bridge advertises a path cost of **0**.
- Each switch adds the **incoming port cost** to the received BPDU.
- Faster links have **lower STP costs**.
- Lowest-cost path wins; tie-breakers apply if costs are equal.



Root Port Tie-Breakers

When path costs are equal, STP chooses:

- **Lowest sender Bridge ID** : **Bridge ID** = Priority + MAC Address
- **Lowest sender port priority**
- **Lowest sender port number**

- STP checks each rule in order;
- The first difference determines the Root Port.

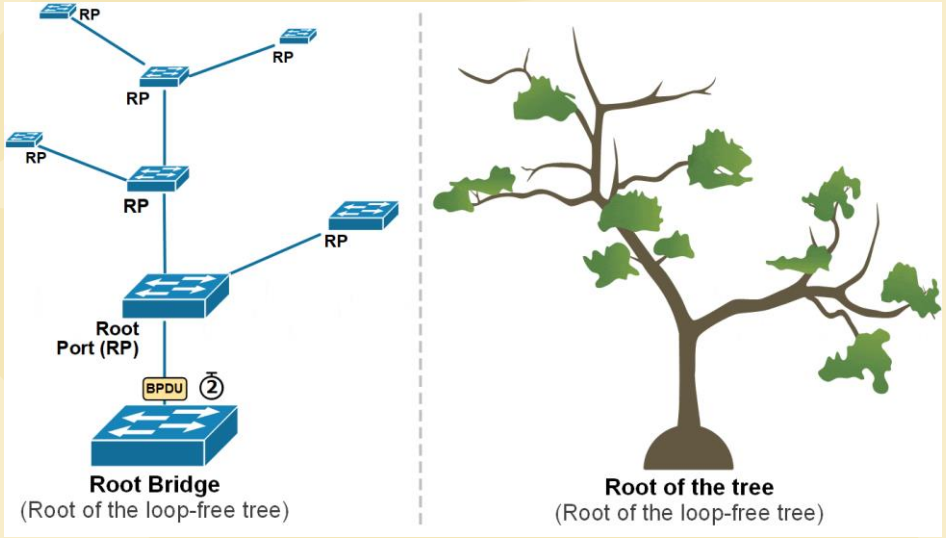
Port Speed	Classic STP Cost
4 Mbps	250
10 Mbps	100
100 Mbps	19
1 Gbps	4
10 Gbps	2
40 Gbps	1

BPDU = Bridge Protocol Data Unit

STP 802.1D

Step 3: Select Designated Ports (DPs)

- **What it is:** One DP is elected on each network segment.
- **What it does:** Forwards traffic and sends the best BPDU toward that segment.
- **Root Bridge rule:** Every active port on the Root Bridge is a DP.



How the DP Is Selected

- Lowest root path cost : Switch A = 19, Switch B = 38 → A wins
- Lowest Bridge ID : Bridge ID = Priority + MAC Address
- Lowest Port ID : Port ID = Port Priority + Port Number
  - A = 128 + Port 1 , B = 128 + Port 2 → A wins
- The losing port becomes **non-designated/blocking.**
  - Does not forward data traffic → **P**prevent loops.

And of course, each is a **tie-breaker in sequence**: Root Path Cost → Bridge ID → Port ID.

BPDU = Bridge Protocol Data Unit


COFFEE BREAK

Switching Security Weaknesses

A switch learns the source MAC address contained in an Ethernet frame without authentication!

Possible problems include:

- MAC address spoofing
- MAC table overflow
- MAC flapping
- Unauthorized devices
- Broadcast storms
- Rogue switches
- Incorrect trunk configuration

Potential consequences:

- Traffic flooding
- Connectivity instability
- Unauthorized network access
- Increased traffic visibility
- Denial of service

Key Point:
An attacker connected to the LAN may therefore attempt to manipulate the switch's learned forwarding information.

MAC Spoofing & MAC Flapping

MAC spoofing: *A device changes its source MAC address to imitate or clone another network interface.*

MAC flapping

- The same MAC address learned on different switch ports.
- The switch continiously updates its MAC table
  - 08:00:27:A4:2B:19 → Port 1
  - 08:00:27:A4:2B:19 → Port 3
  - 08:00:27:A4:2B:19 → Port 1

Possible effects:

- Incorrect frame forwarding
- Packet loss
- Intermittent connectivity
- Switch log warnings
- Network instability

Possible indicators:

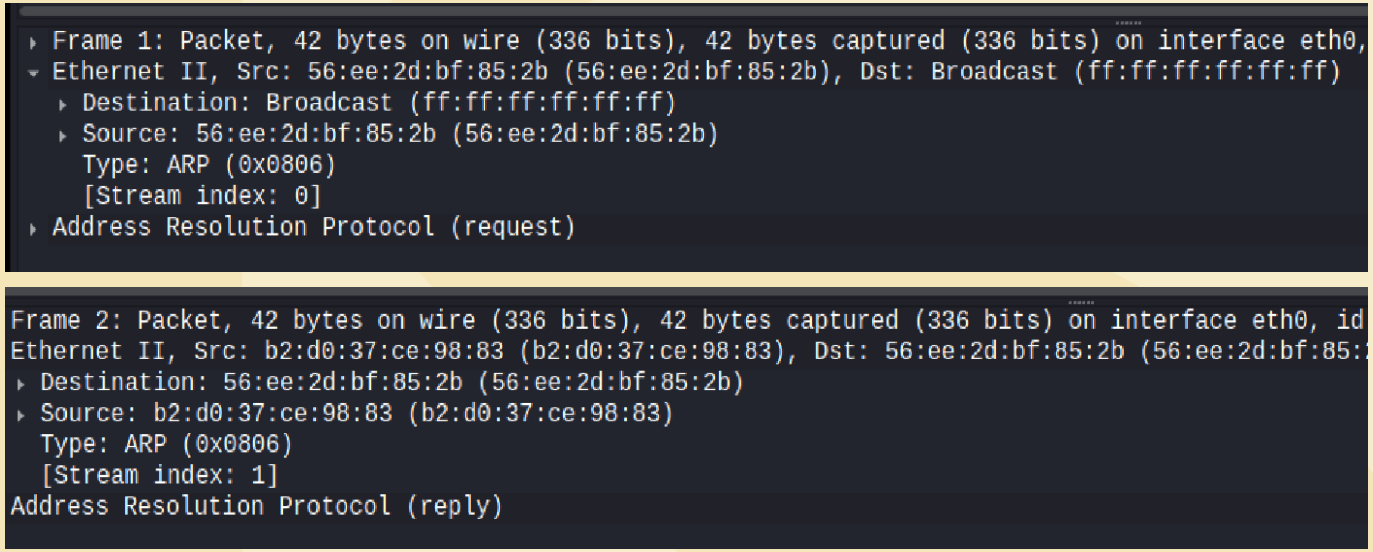
- Rapid MAC-table changes
- Intermittent connectivity
- Packet loss
- Switch log warnings.

ARP: Address Resolution Protocol

ARP Role: Maps IPv4 address to MAC address

- IPv4 applications use IP addresses
- Ethernet requires MAC addresses.

- ARP works only inside the local Layer 2 broadcast domain.



ERHVERVSAKADEMI KØBENHAVN

ARP

ARP Request — “Who has X? Tell Y”

An ARP Request is used when a host knows the destination IPv4 address but does not know its MAC address.

Example: Who has 192.168.1.20? Tell 192.168.1.10

1. 192.168.1.10 wants to communicate with 192.168.1.20
2. It checks its ARP cache
3. If no valid mapping exists, it sends an ARP Request
4. The request is sent as a Layer 2 broadcast
5. The owner of 192.168.1.20 replies with its MAC address

When does it happen?

1. When no ARP entry exists
2. When an entry must be refreshed or verified
3. When a host communicates with a new local IPv4 destination

ARP Requests are normally event-driven, not continuously sent.

Example reply:
192.168.1.20 is at AA:BB:CC:DD:EE:FF

ARP

ARP Probe — “Is Anyone Using This IP?”

- *An ARP Probe is used before a host starts using an IPv4 address.*
- *Its purpose is to check whether another host is already using that address.*

Example:
- Sender IP: 0.0.0.0 Target IP: 192.168.1.20
- The host is effectively asking:
- Is anyone already using 192.168.1.20?

Happen typically when:
- A host receives or configures a new IPv4 address
- A host reconnects to a network
- Duplicate Address Detection is performed

ARP Probe = check before claiming an IP address.

Why is the sender IP 0.0.0.0?
Because the host has not yet claimed the address.
It is checking for an address conflict before using it.

ARP

ARP Announcement — “This IP Is Mine”

An ARP Announcement is sent when a host advertises its own IP-to-MAC mapping.

Example:
Sender IP: 192.168.1.20 Target IP: 192.168.1.20 Sender MAC: AA:BB:CC:DD:EE:FF
Conceptually:

- 192.168.1.20 is at AA:BB:CC:DD:EE:FF
- The sender IP and target IP are typically the same.

Why send it?

- Announce a newly configured IP address
- Update other hosts' ARP caches
- Correct stale mappings
- Support failover or IP movement

Important
An ARP Announcement is normally **unsolicited**. No host needs to ask for it first.

Simply put: ARP Announcement = advertise or refresh an IP-to-MAC mapping.

ARP

ARP / Neighbor Table

Once a host learns an IP-to-MAC mapping, it stores it in its neighbor table.
The operating system also keeps track of the **state** of each entry:

- **REACHABLE** — Recently confirmed
- **STALE** — Known, but not recently verified
- **FAILED** — No response from the neighbor
- **PERMANENT** — Static mapping; does not expire

The state helps the OS decide whether it can **reuse the cached MAC address** or needs to perform ARP again.

ARP / Neighbor Table

OS	Typical dynamic ARP behavior
Linux	REACHABLE for about **15–45 seconds** by default, then usually becomes **STALE**. Stale entries may remain longer until reused or garbage-collected. (Kernel.org)
Windows	REACHABLE for about **15–45 seconds**, then becomes **STALE** if unused. Windows revalidates it when needed. (Microsoft Learn)
macOS	Dynamic ARP entries may remain cached for roughly **20 minutes after validation**, depending on use and system behavior. (manp.gs — man pages)

What is the difference?

```
▸ Frame 1: Packet, 42 bytes on wire (336 bits), 42 bytes captured (336 bits) on interface eth0,
▾ Ethernet II, Src: 56:ee:2d:bf:85:2b (56:ee:2d:bf:85:2b), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
  ▸ Destination: Broadcast (ff:ff:ff:ff:ff:ff)
  ▸ Source: 56:ee:2d:bf:85:2b (56:ee:2d:bf:85:2b)
    Type: ARP (0x0806)
    [Stream index: 0]
▸ Address Resolution Protocol (request)
```

```
▸ Frame 69: Packet, 42 bytes on wire (336 bits), 42 bytes captured (336 bits) on interface eth0, id 0
▾ Ethernet II, Src: 56:ee:2d:bf:85:2b (56:ee:2d:bf:85:2b), Dst: b2:d0:37:ce:98:83 (b2:d0:37:ce:98:83)
  ▸ Destination: b2:d0:37:ce:98:83 (b2:d0:37:ce:98:83)
  ▸ Source: 56:ee:2d:bf:85:2b (56:ee:2d:bf:85:2b)
    Type: ARP (0x0806)
    [Stream index: 1]
▸ Address Resolution Protocol (request)
```

```
▾ Ethernet II, Src: ae:07:75:a0:a8:64 (ae:07:75:a0:a8:64), Dst: 56:ee:2d:bf:85:2b (56:ee:2d:bf:85:2b)
  ▸ Destination: 56:ee:2d:bf:85:2b (56:ee:2d:bf:85:2b)
  ▸ Source: ae:07:75:a0:a8:64 (ae:07:75:a0:a8:64)
    Type: ARP (0x0806)
    [Stream index: 10]
▾ Address Resolution Protocol (reply)
    Hardware type: Ethernet (1)
    Protocol type: IPv4 (0x0800)
    Hardware size: 6
    Protocol size: 4
    Opcode: reply (2)
    Sender MAC address: ae:07:75:a0:a8:64 (ae:07:75:a0:a8:64)
    Sender IP address: 192.168.64.1
    Target MAC address: 56:ee:2d:bf:85:2b (56:ee:2d:bf:85:2b)
    Target IP address: 192.168.64.3
```

ARP Communication

Step 1: Check ARP cache
The sender checks whether it already knows the destination MAC address.

Step 2: ARP request
If the mapping is unknown, the sender broadcasts: Who has 192.168.64.20? Tell ….

Step 3: ARP reply
The owner responds, normally using unicast: 192.168.64.20 is at AA:BB:CC:DD:EE:FF

Step 4: Cache the result
The sender temporarily stores the IP-to-MAC mapping.

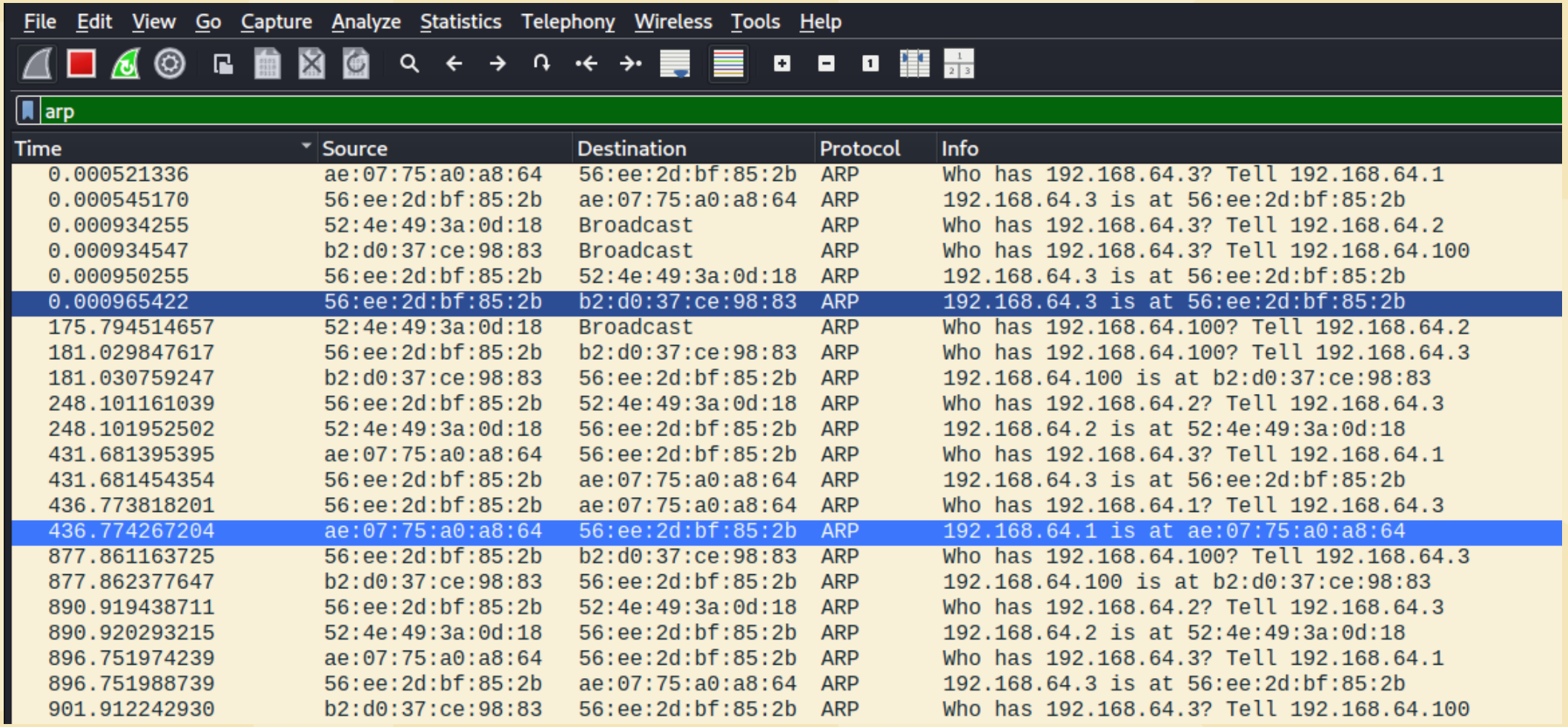
Linux commands (To see your ARP table):

```
ip neigh
arp -a
```

What Security measure is missing in the reply data? Think CIA triad!

Can you think of a way of exploiting it?

Normal ARP Com example

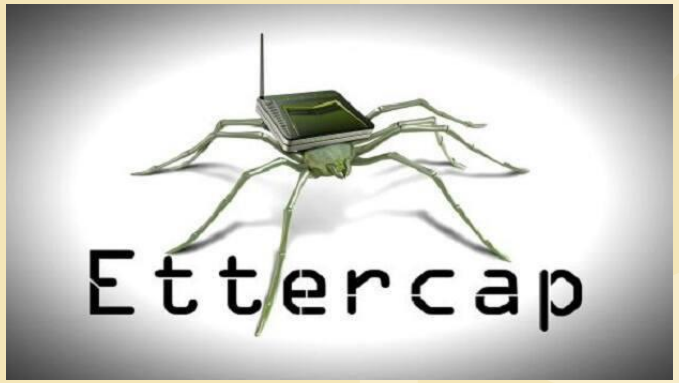


Time	Source	Destination	Protocol	Info
0.000521336	ae:07:75:a0:a8:64	56:ee:2d:bf:85:2b	ARP	Who has 192.168.64.3? Tell 192.168.64.1
0.000545170	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	192.168.64.3 is at 56:ee:2d:bf:85:2b
0.000934255	52:4e:49:3a:0d:18	Broadcast	ARP	Who has 192.168.64.3? Tell 192.168.64.2
0.000934547	b2:d0:37:ce:98:83	Broadcast	ARP	Who has 192.168.64.3? Tell 192.168.64.100
0.000950255	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	192.168.64.3 is at 56:ee:2d:bf:85:2b
0.000965422	56:ee:2d:bf:85:2b	b2:d0:37:ce:98:83	ARP	192.168.64.3 is at 56:ee:2d:bf:85:2b
175.794514657	52:4e:49:3a:0d:18	Broadcast	ARP	Who has 192.168.64.100? Tell 192.168.64.2
181.029847617	56:ee:2d:bf:85:2b	b2:d0:37:ce:98:83	ARP	Who has 192.168.64.100? Tell 192.168.64.3
181.030759247	b2:d0:37:ce:98:83	56:ee:2d:bf:85:2b	ARP	192.168.64.100 is at b2:d0:37:ce:98:83
248.101161039	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	Who has 192.168.64.2? Tell 192.168.64.3
248.101952502	52:4e:49:3a:0d:18	56:ee:2d:bf:85:2b	ARP	192.168.64.2 is at 52:4e:49:3a:0d:18
431.681395395	ae:07:75:a0:a8:64	56:ee:2d:bf:85:2b	ARP	Who has 192.168.64.3? Tell 192.168.64.1
431.681454354	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	192.168.64.3 is at 56:ee:2d:bf:85:2b
436.773818201	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	Who has 192.168.64.1? Tell 192.168.64.3
436.774267204	ae:07:75:a0:a8:64	56:ee:2d:bf:85:2b	ARP	192.168.64.1 is at ae:07:75:a0:a8:64
877.861163725	56:ee:2d:bf:85:2b	b2:d0:37:ce:98:83	ARP	Who has 192.168.64.100? Tell 192.168.64.3
877.862377647	b2:d0:37:ce:98:83	56:ee:2d:bf:85:2b	ARP	192.168.64.100 is at b2:d0:37:ce:98:83
890.919438711	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	Who has 192.168.64.2? Tell 192.168.64.3
890.920293215	52:4e:49:3a:0d:18	56:ee:2d:bf:85:2b	ARP	192.168.64.2 is at 52:4e:49:3a:0d:18
896.751974239	ae:07:75:a0:a8:64	56:ee:2d:bf:85:2b	ARP	Who has 192.168.64.3? Tell 192.168.64.1
896.751988739	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	192.168.64.3 is at 56:ee:2d:bf:85:2b
901.912242930	b2:d0:37:ce:98:83	56:ee:2d:bf:85:2b	ARP	Who has 192.168.64.3? Tell 192.168.64.100

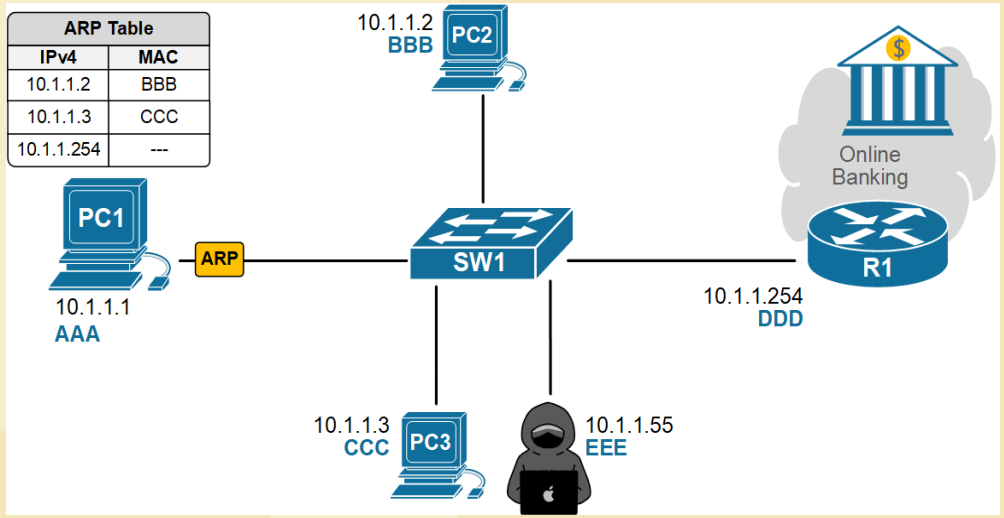
ARP Cache

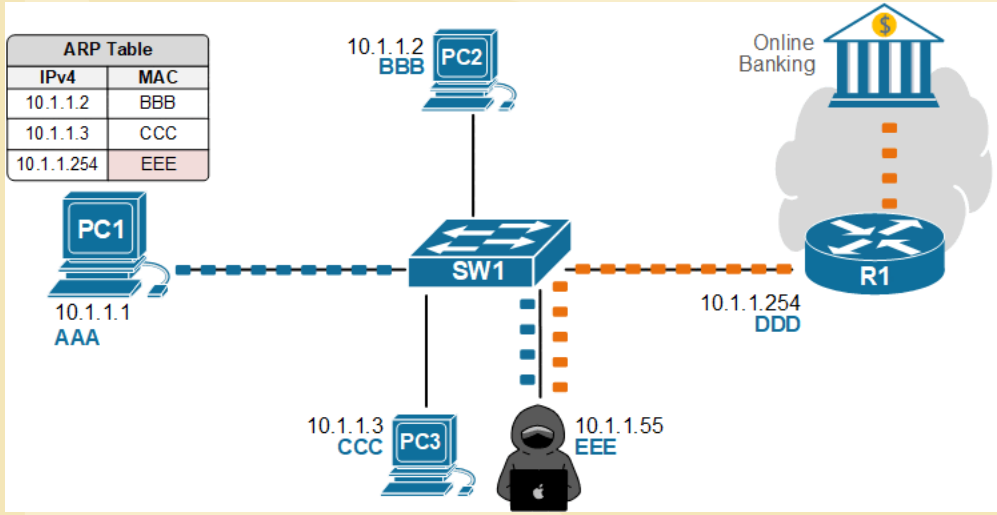


- **MITM Attack on LAN**
- **Possible outcomes:**
  - ✓ Traffic redirection
  - ✓ Traffic inspection
  - ✓ Packet modification
  - ✓ Denial of service



ARPSPOOF CMD





https://linux.die.net/man/8/arpspoof

ARP Cache



Time	Source	Destination	Protocol	Info
1494.612198385	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	192.168.64.1 is at 56:ee:2d:bf:85:2b
1494.612207844	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	192.168.64.2 is at 56:ee:2d:bf:85:2b
1494.622261638	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	192.168.64.100 is at 56:ee:2d:bf:85:2b
1494.622271346	56:ee:2d:bf:85:2b	b2:d0:37:ce:98:83	ARP	192.168.64.1 is at 56:ee:2d:bf:85:2b
1494.632338265	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	192.168.64.2 is at 56:ee:2d:bf:85:2b
1494.632346182	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	192.168.64.1 is at 56:ee:2d:bf:85:2b
1495.589115047	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	Who has 192.168.64.1? Tell 192.168.64.3
1495.589133339	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	Who has 192.168.64.2? Tell 192.168.64.3
1495.589389673	ae:07:75:a0:a8:64	56:ee:2d:bf:85:2b	ARP	192.168.64.1 is at ae:07:75:a0:a8:64
1495.589389715	52:4e:49:3a:0d:18	56:ee:2d:bf:85:2b	ARP	192.168.64.2 is at 52:4e:49:3a:0d:18
1504.642504930	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	192.168.64.100 is at 56:ee:2d:bf:85:2b
1504.642518597	56:ee:2d:bf:85:2b	b2:d0:37:ce:98:83	ARP	192.168.64.2 is at 56:ee:2d:bf:85:2b
1504.652589516	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	192.168.64.1 is at 56:ee:2d:bf:85:2b
1504.652598891	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	192.168.64.2 is at 56:ee:2d:bf:85:2b
1504.662666810	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	192.168.64.100 is at 56:ee:2d:bf:85:2b
1504.662677518	56:ee:2d:bf:85:2b	b2:d0:37:ce:98:83	ARP	192.168.64.1 is at 56:ee:2d:bf:85:2b
1504.672747271	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	192.168.64.2 is at 56:ee:2d:bf:85:2b
1504.672757021	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	192.168.64.1 is at 56:ee:2d:bf:85:2b
1514.682933170	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	192.168.64.100 is at 56:ee:2d:bf:85:2b
1514.682949462	56:ee:2d:bf:85:2b	b2:d0:37:ce:98:83	ARP	192.168.64.2 is at 56:ee:2d:bf:85:2b
1514.693817884	56:ee:2d:bf:85:2b	52:4e:49:3a:0d:18	ARP	192.168.64.1 is at 56:ee:2d:bf:85:2b
1514.693828218	56:ee:2d:bf:85:2b	ae:07:75:a0:a8:64	ARP	192.168.64.2 is at 56:ee:2d:bf:85:2b

- Who is the bad host?
- Who is the victim(s)

ARP Cache



Indicators / Detection

Indicators

- Repeated unsolicited ARP replies
- Unexpected ARP traffic volume
  - Higher than usual.
  - Faster than Usual!
- Gateway MAC address changes unexpectedly
- Unexpected or rapidly changing IP-to-MAC mappings.
- Duplicate IP warnings
- Intermittent connectivity

Detection

- **arpwatch** — monitors IP–MAC mappings and detects unexpected changes.
- **Switch logging / monitoring** — can reveal MAC changes, port-security violations, DAI drops, etc.
- **Dynamic ARP Inspection (DAI)** — inspects ARP traffic and detects invalid IP–MAC mappings.

ARP Cache



Mitigation / Prevention

Static ARP entries:
- Protect selected critical systems from accepting forged ARP mappings.

DHCP Snooping:
- Builds trusted **IP–MAC–VLAN–port bindings** used by DAI.

Dynamic ARP Inspection (DAI):
- Drops invalid/spoofed ARP packets.

VLAN segmentation *Next lecture:
- **contains** ARP poisoning to a smaller broadcast domain; does not prevent it within the VLAN.

Port Security:
- restricts which/how many MAC addresses can appear on a switch port.

Network Access Control (e.g., 802.1X):
- restricts network access to authenticated/authorized users or devices.

PNAC = Port-Based Network Access Control

ARP Cache  Demo

Lab Topology:

- Kali VM (Attacker)
- Ubuntu Server VM 1:Victim


COFFEE BREAK

Dynamic Host Configuration Protocol (DHCP)

- **Application-level protocol.**
- **Uses UDP port 53 for transport**
- DHCP automatically provides network configuration.
- Common DHCP information includes:
  - ✓ IP address
  - ✓ Subnet mask
  - ✓ Default gateway
  - ✓ DNS servers
  - ✓ Lease duration
  - ✓ Domain information
  - ✓ Other DHCP options

DHCP reduces manual configuration but creates a trusted onboarding process.

Security importance: DHCP can influence where a device sends traffic and how it resolves names.

DHCP server is on the same LAN *Home networks:

- DHCP Uses LINK layer as transport

DHCP server is Not on the same LAN

The usual setup on organizations networks:

- Router don't forward Broadcasts!
- **DHCP Relay Agent** on the router.
- Layer-3 switch

DHCP DORA

DORA = Discover → Offer → Request → Acknowledge



1. **Discover:** The client **broadcasts** a request for DHCP configuration.
   - ✓ Source IP: 0.0.0.0
   - ✓ Destination IP: 255.255.255.255

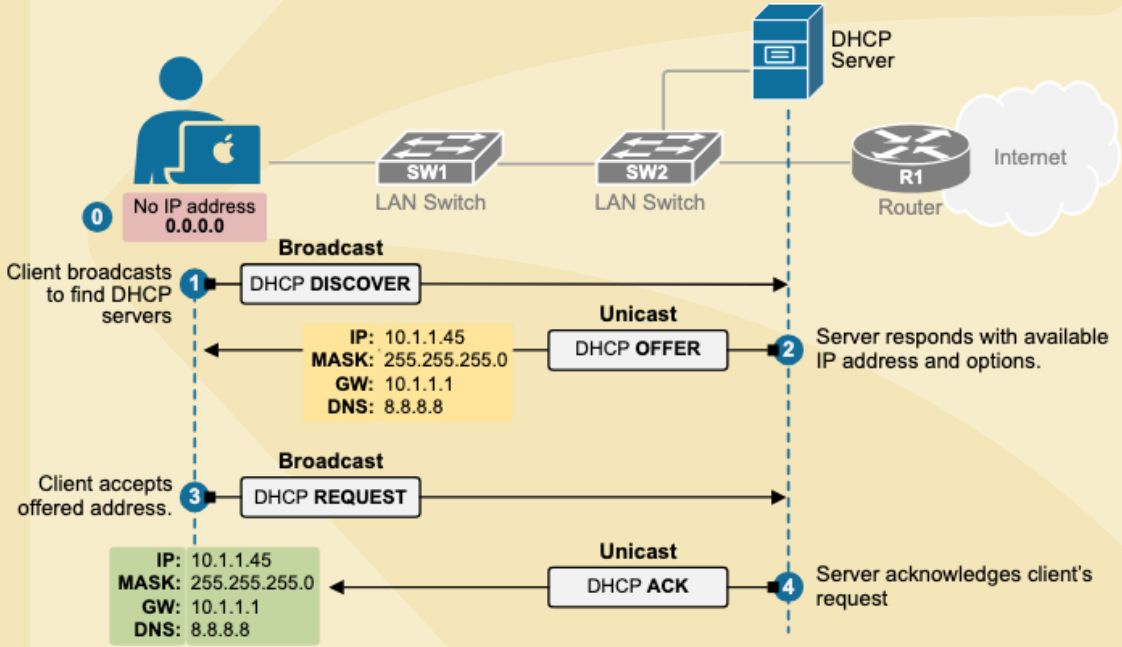
2. Offer: A DHCP server offers an IP address and configuration.

3. Request: The client requests one of the offered configurations.

4. Acknowledgment: The server confirms the lease.

1. *Why is Source IP is 0.0.0.0?*
2. *Why Destination is 255.255.255.255?*

```
sudo dhclient -r eth0
sudo dhclient -v eth0
```



DHCP

APIPA / IPv4 Link-Local Addressing

When DHCP fails or no DHCP server is available, a host can automatically assign itself a Link-Local (APIPA) address.

Flow: DHCP request → No response → Link-Local 169.254.x.x

- **Range:** 169.254.0.0/16
- **RFC Usable auto-assignment:** 169.254.1.0 – 169.254.254.255
- **Mask:** 255.255.0.0 (/16)
- Uses ARP to check that the selected address is not already in use
- Communication is limited to the **local network/link**
- **Not routable** → normally no Internet or other subnet access
- A 169.254.x.x address often indicates a **DHCP problem**

RFC 3927 — Dynamic Configuration of IPv4 Link-Local Addresses

Microsoft Learn — Automatic TCP/IP Addressing without a DHCP Server

APIPA = Automatic Private IP Addressing (Microsoft terminology)

DHCP Attacks

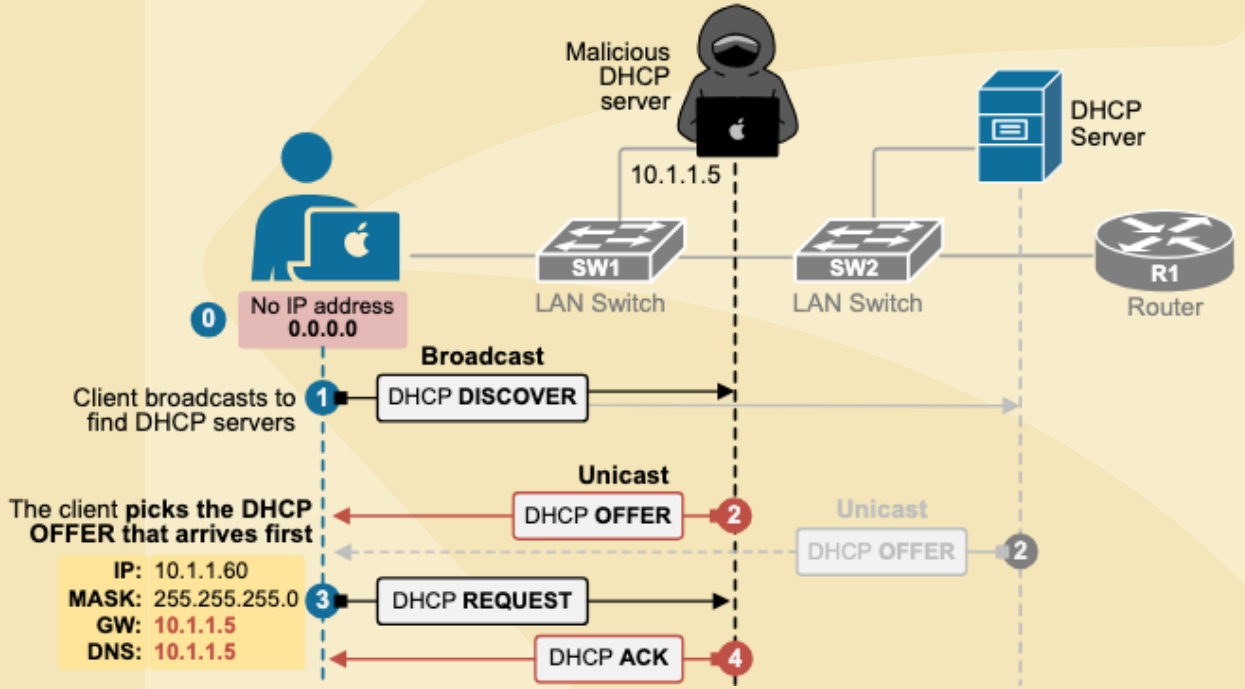
Rogue DHCP Server

Possible malicious configuration:

- Attacker-controlled default gateway
- Attacker-controlled DNS server
- Incorrect subnet mask
- Invalid routes
- Very short lease duration

Detection indicators

- Multiple DHCP Offers for one Discover
- Unexpected DHCP server addresses
- Incorrect gateway or DNS configuration
- DHCP responses originating from user-facing ports

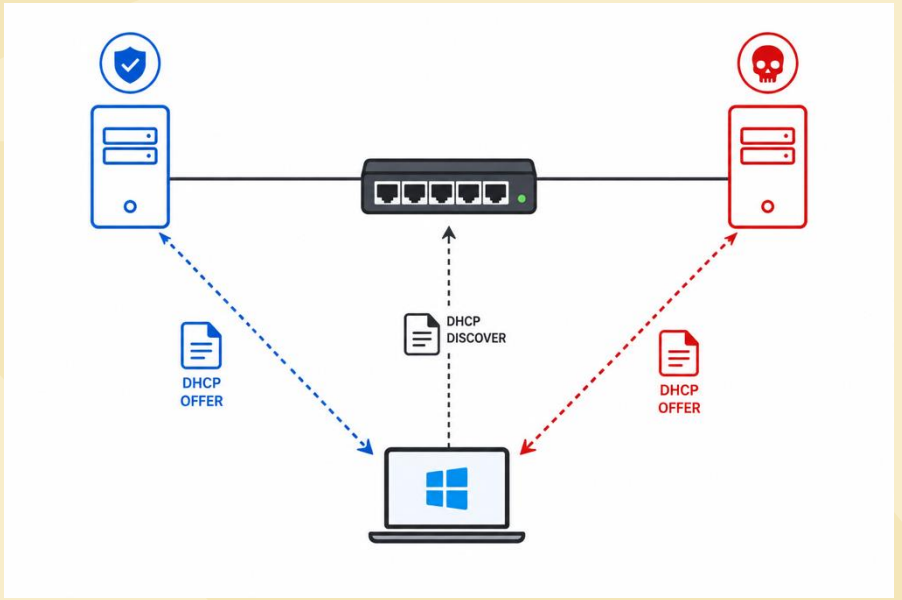


DHCP Rogue station++

- Unauthorized DHCP server connected to the network.
- Sends fake IP address, gateway, or DNS information to clients.
- Can redirect user traffic through an attacker.
- May cause loss of connectivity or network disruption.

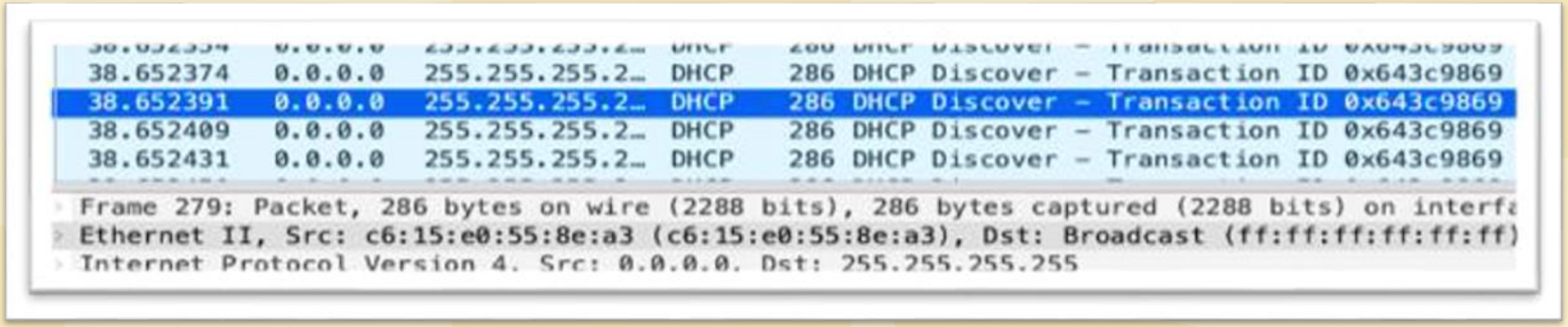
Detection indicators

- DHCP Offer/Ack coming from an access (untrusted) port.
- Multiple DHCP servers responding to the same DHCP Discover.
- DHCP responses from an unknown or unauthorized IP/MAC address.
- Clients receiving an unexpected default gateway or DNS server.
- Sudden changes in the DHCP server identifier seen on the network.



DHCP Snooping can block DHCP replies from untrusted ports.

DHCP Starvation



Traffic characteristics:

- Large numbers of DHCP Discover messages
- Rapid packet generation
- Many apparently new MAC addresses
- Repeated lease allocation attempts
- Abnormal transaction ID patterns
- DHCP pool depletion

Detection indicators

- High Volume of DHCP transactions *Discover.
- Small time intervals between every Discover.
- Same Transaction ID (Can be changed).
- Same Port but many Discover and MAC Addr!

What do you call this type of attack when a user cannot use a services?

DHCP Defense

Port Security / MAC limiting

- Cap the number of MAC addresses per access port (e.g., 1–3)
- Optionally *sticky MAC* + shutdown/restrict on violation

DHCP Snooping

- Classifies switch ports as trusted or untrusted
- Allows DHCP server responses only from trusted ports
- Blocks rogue DHCP responses from access ports
- Creates an IP–MAC–VLAN–port binding table.

Rate limiting

Limits excessive DHCP, broadcast or unknown unicast traffic

Monitoring:

- DHCP server logs
- SIEM alerts on abnormal lease

IP Source Guard + Dynamic ARP Inspection

Enforce IP MAC bindings learned via snooping (limits spoofing abuse*) **(vendor feature)***

802.1X / NAC (identity-based access)

- Only authenticated devices can get network access (and DHCP lease)
- Use guest/VLAN fallback or block for unknown endpoints

Switch Security Controls

Port security

Controls which and/or how many MAC addresses may use a switch port.



Possible settings:

- Maximum number of MAC addresses per port
- Static allowed MAC addresses
- Sticky MAC learning

Violation action:

- ✓ **Shutdown:** Disables the port; all traffic stops.
- ✓ **Restrict:** Drops unauthorized traffic and logs it.
- ✓ **Protect:** Silently drops unauthorized traffic; authorized traffic continues.

Switch Security Controls

Port Mirroring

Port mirroring copies traffic from one or more switch ports to another monitoring port.

Defensive use

- Monitor traffic without interrupting communication
- Capture packets with Wireshark
- Feed traffic to IDS/IPS or network monitoring systems
- Investigate suspicious activity and incidents

Attacker perspective

- If an attacker gains access to a mirror/SPAN port, they may observe traffic from other hosts
- Misconfigured monitoring ports can expose sensitive network traffic
- Mirrored traffic can reveal protocols, credentials, metadata, and network behavior

Security principle:

Port mirroring is a powerful visibility tool, but access to the monitoring port must be protected.

L2 Security summary

Threat	Primary control
Unauthorized endpoint	802.1X / NAC
Excessive MAC addresses	Port security
Rogue DHCP server	DHCP Snooping
DHCP starvation	MAC limits and DHCP rate limiting
ARP poisoning	Dynamic ARP Inspection
Lateral movement	VLAN segmentation and ACLs
Broadcast storm	Storm control and STP
Rogue switch	BPDU Guard and port configuration
MAC flapping	Port security and monitoring

Dynamic ARP Inspection

- Checks ARP messages against valid DHCP Snooping bindings.
- Helps block invalid IP-to-MAC claims.

IP Source Guard

Restricts IP traffic based on trusted IP-to-MAC-to-port bindings.


BREAK
TIME

LAB Lesson

Part I attack and defense (red team+ Blue team):

- Conduct ARP cache poisoning on 1 VM target.
- Implement detection & prevention *Observe and learn.

Part II: DFIR (Deliverable) Blue team:
Inspect a pcap file and do digital forensics> solve the digital crime scene



Part III: DHCP starvation attack (Optional):

- Conduct and observer DHCP starvation attack

